Shadow IT — PoC Técnico

Sep 24, 2026 · @Jader Paim

1. Visão geral e objetivo

O **Shadow IT** é o módulo de visibilidade de rede interna do b-security: encontra e cataloga dispositivos/serviços na rede que não têm registro DNS conhecido nem cadastro formal (CMDB), e enriquece cada host achado com o que ele expõe — compartilhamentos SMB, banners FTP, títulos de página HTTP/HTTPS, nome NetBIOS.

O nome “Shadow IT” descreve exatamente o problema que o módulo resolve: equipamento, serviço ou compartilhamento que existe e está acessível na rede, mas que ninguém documentou formalmente — risco clássico de segurança corporativa (compartilhamento SMB aberto sem controle, servidor de teste esquecido exposto, serviço legado sem dono). O módulo não tenta *impedir* Shadow IT — tenta torná-lo **visível e auditável**, com triagem (esperado / revisar / crítico) e fluxo de resolução.

É um módulo irmão do DAST Scanner (documento próprio) — compartilha infraestrutura de scan, mas por decisão de projeto **nunca compartilha dado**: um host de aplicação (nome DNS resolvido) vai pro DAST; um host sem nome resolvível vai pro Shadow IT.

2. Arquitetura — infraestrutura compartilhada, dados separados



Por que compartilha infra mas nunca dado: o comentário de cabeçalho de `shadowit.functions.ts` explica isso de forma direta — fila, endpoints (`/shadowit/scan`, `/shadowit/discover`) e tabela de status são **próprios**, "nunca tocam `dast_scans` / `dast_recon_subdomains`, mesmo rodando no mesmo FastAPI e reaproveitando `is_dast_allowed()` como controle de acesso (mesmo time audita os dois módulos hoje) e as mesmas credenciais/infra de chamada". A razão prática: uma varredura de subnet inteira não pode travar a fila serial de scan de vulnerabilidade do DAST, e vice-versa — filas separadas garantem isso mesmo compartilhando o mesmo processo Python.

Critério de separação de dado (a regra que decide se um host vai pro DAST ou pro Shadow IT), documentado na migration fundadora: *"hosts internos achados pelo ping sweep que NÃO resolveram hostname em DNS interno — dispositivo sem registro conhecido, por definição não é candidato a scan de aplicação."* Essa regra foi **corrigida em produção no mesmo dia da criação do módulo** (ver linha do tempo) depois que um teste real mostrou hosts internos com hostname resolvido caindo errado em Ativos Descobertos do DAST — o critério final é mais simples: **toda** descoberta de rede interna (com ou sem nome) é Shadow IT; o DAST fica exclusivamente com descoberta externa.

3. Linha do tempo de construção

Data	Marco
20/08/2026	Precursor: `dast_recon_subdomains` ganha uma coluna `scope` (externo/interno) — primeiro sinal da distinção que viraria o Shadow IT, ainda dentro do DAST.

Data	Marco
28/08/2026	**Módulo criado do zero, num único dia**: `ShadowIt.tsx`, `shadowit.functions.ts`, `shadowit.server.ts`, `shadowit-callback.ts`, helper de criptografia AES-256-GCM novo, as 3 tabelas principais (`shadowit_hosts`, `shadowit_scans`, `shadowit_findings`), cadastro no menu lateral e no roteamento. **No mesmo dia**, correção de critério: um teste real mostrou host interno com hostname resolvido caindo errado no DAST — regra ajustada pra "toda descoberta interna é Shadow IT" (coluna `hostname` adicionada, limpeza dos registros que tinham ido pro lugar errado).
04/09/2026	Detalhe de host migra de painel fixo embaixo da tabela pra **Sheet lateral** com alça de redimensionar, no mesmo padrão já usado no módulo de Vulnerabilidades — unificação de UX pedida pelo usuário.
08/09/2026	Passada de formatação (sem mudança funcional).
21/09/2026	Endurecimento de sessão em todo o app: as 9 server functions do Shadow IT passam a usar `requireActiveSession`, junto com ~45 outros módulos.

Sem mudança funcional específica registrada desde 21/09 — módulo estável há cerca de 3 dias no momento deste documento (24/09), após 24 dias de ajustes incrementais de UX/segurança seguindo a construção inicial.

4. Capacidades atuais

Inventário de hosts — alimentado de duas formas: passivamente, por qualquer host que o ping sweep interno do DAST encontre sem hostname resolvível, e ativamente, por uma **varredura de subnet sob demanda** dentro do próprio Shadow IT ("Nova varredura", só faixas privadas RFC1918).

Enriquecimento — por host (botão individual) ou em massa (“Verificar todos”): sonda compartilhamentos SMB (com classificação de governança esperado/revisar/crítico e permissão leitura/escrita), banner FTP, título e status de página HTTP/HTTPS, e nome/workgroup NetBIOS.

Painel de Hosts — 5 KPIs (Hosts, HTTP/HTTPS com título, FTP, Compartilhamentos SMB, Críticos), tabela ordenável com badge de serviço por host, badge de presença no CMDB (cruzamento automático), e clique no host abre o detalhe lateral.

Detalhe do host — cartões de NetBIOS/HTTP/HTTPS/FTP e a lista de compartilhamentos SMB, cada um com classificação e ações de triagem (marcar resolvido / falso positivo).

Painel de Varreduras — histórico completo de scans (nome, alvos, status, duração), com cancelamento enquanto ativo e exclusão quando finalizado.

Credencial SMB dedicada — sessão anônima é bloqueada na rede, então a enumeração de compartilhamento depende de uma credencial de domínio própria, cifrada, nunca reexibida.

Achados reabrem sozinhos — igual ao DAST: encontrar o mesmo compartilhamento/serviço numa varredura posterior atualiza o registro existente (contagem de ocorrências, reabertura automática se já tinha sido marcado resolvido/falso positivo) em vez de duplicar.

5. Modelo de dados e credenciais

`shadowit_hosts` — IP (identidade, normalizado e único), hostname (se resolvido), MAC, fonte (nmap por padrão), primeira/última vez visto. **`shadowit_scans`** — fila e status próprios (queued/running/done/error/cancelled), alvos, progresso. **`shadowit_findings`** — achado tipado (`smb_share` / `ftp_banner` / `http_title` / `netbios`), classificação de governança, status de triagem (open/resolved/false_positive), identidade única por (IP, tipo, nome) pra permitir reabertura em vez de duplicação.

Três credenciais separadas de propósito, mesmo quando na prática apontam pra mesma conta de domínio:

Credencial	Módulo	Uso
SMB (`shadowit_smb`)	Shadow IT	Enumerar compartilhamento de rede
AD/LDAP (`dast_ad_ldap`)	DAST	Descoberta de aplicação interna via zona DNS AD

Credencial	Módulo	Uso
Autenticação por domínio	DAST	Login em cada aplicação escaneada (white box)

A justificativa documentada no código: “cada módulo gerencia/rotaciona a sua, mesmo que na prática aponte pra mesma conta de domínio” — evita acoplamento entre módulos que, se uma credencial precisar mudar ou ser revogada num contexto, não quebra o outro sem querer.

Todas cifradas com **AES-256-GCM** na tabela `integrations`; a senha nunca é devolvida pra tela, só “configurada como: {usuário}”. No momento do scan, a credencial é decifrada e enviada por requisição pro scanner — nunca fica persistida na VM.

6. Decisões de segurança específicas

Caminho UNC nunca vira link clicável. O compartilhamento SMB de cada host é mostrado como `\\ip\share`, mas só como texto copiável (botão de copiar), nunca como um `<a href="file://...">`. Motivo documentado no código: um link `file://\\host\share` clicável dispararia autenticação SMB forçada no navegador do analista — risco real de **vazamento de hash NTLM** (o navegador tenta autenticar automaticamente no host remoto só de renderizar/seguir o link, sem o usuário digitar nada). Os cartões HTTP/HTTPS, em contraste, usam link de verdade (`target="_blank"`) — protocolo diferente, risco diferente, tratamento deliberadamente diferente.

Sem sessão anônima. A rede-alvo já bloqueia SMB anônimo por política — o módulo depende inteiramente da credencial de domínio cadastrada pra enumerar qualquer coisa; sem credencial, essa parte da varredura simplesmente fica vazia (comportamento visto como aceitável, não um erro).

Acesso emprestado do DAST, não um risco novo. Como o Shadow IT reusa `is_dast_allowed()` em vez de ter grupo próprio, ele herda automaticamente qualquer endurecimento futuro feito nessa função (ex.: a inclusão de `super_admin` em 25/08 valeu pros dois módulos sem precisar de mudança específica aqui).

7. Limitações conhecidas e pendências

- **Sem grupo de permissão próprio** — mesma lacuna do DAST, documentada explicitamente na migration fundadora como um ponto de troca fácil no futuro (“se precisar de grupo de acesso próprio, é só trocar a função usada nas policies”), mas

ainda não feito.

- **Sem chave de API própria** — reutiliza a mesma credencial `dast_scanner` pra falar com a VM; não existe uma chave específica do Shadow IT.
- **`shadowit_findings.scan_id` pode ficar órfão** — deliberado (excluir histórico de scan não apaga achados, mesmo padrão do DAST), mas significa que o vínculo com o scan de origem pode apontar pra um registro que não existe mais.
- **Preferência de ordem de colunas é só local** (localStorage do navegador) — não sincroniza entre dispositivos nem sessões.
- **Descoberta de subnet aceita só uma faixa CIDR por vez** — sem varredura em lote de múltiplas subnets numa única ação.
- **Diálogo de credencial não testa a conexão antes de salvar** — aceita e cifra o que for digitado; erro só aparece depois, no campo de erro de um scan subsequente.

8. Estado atual e conclusão

O Shadow IT nasceu como um recurso completo num único dia (28/08), incluindo uma correção de critério no mesmo dia baseada em teste real — sinal de um desenho que foi validado contra dado de produção desde o começo, não só no papel. Desde então recebeu um ajuste de UX (Sheet lateral, 04/09) e o mesmo endurecimento de sessão aplicado a todo o app (21/09), permanecendo funcionalmente estável há cerca de três semanas.

É um módulo deliberadamente enxuto: sem motor de scan complexo pra manter (reusa o ping sweep e a infraestrutura do DAST), sem grupo de permissão próprio pra administrar, focado num único trabalho — dar visibilidade sobre o que existe na rede sem registro formal, com o cuidado extra de não introduzir risco novo no processo (o caso do link UNC é o exemplo mais claro disso).

As pendências listadas (seção 7) são de escala/conveniência, não de funcionamento — nenhuma impede o uso atual pelo time de Segurança da Informação.